

Department of Software Engineering



Software Verification and Validation Lab

FINAL COMPLIANCE DOSSIER

Submitted by	
Members	Laiba Majeed – Fa2023-BSSE-125
Semester	6 th Semester
Section	D Section
Domain Title:	Hospital Management System

Submitted To
Maam Jawaria Ramzan

Table of Contents

1. Project Overview3

 1.1 Scope & Environment3

2. Summary of Security Validation (Week 13)4

 2.1 Alert Count by Risk Level.....4

 2.2 Vulnerabilities Identified.....4

3. Validation Risk Register.....5

4. Evidence Summary.....6

 4.1 Compliance Folder Structure.....6

5. Mitigation Actions.....7

6. Conclusion.....7

1. Project Overview

This compliance dossier documents the security validation activities conducted during Week 13-14 of the software development lifecycle. The validation was performed using OWASP ZAP (Zed Attack Proxy) version 2.17.0 against the OWASP Juice Shop demo application — a deliberately vulnerable web application used for training and validation purposes.

The primary objective was to identify security vulnerabilities, assess their risk levels, compile evidence, and produce a structured compliance package suitable for audit review.

1.1 Scope & Environment

Parameter	Value
Target URL	https://demo.owasp-juice.shop
Scan Tool	OWASP ZAP by Checkmarx v2.17.0
Scan Date	Wednesday, 20 May 2026 at 16:08:59
Scan Type	Passive Scanner (Spider + Passive Rules)
Total Endpoints	135 endpoints crawled
Environment	Demo / Lab System (OWASP Juice Shop)
Prepared By	Validation Engineering Team
Review Type	Compliance Audit — Week 14

2. Summary of Security Validation (Week 13)

The OWASP ZAP passive scan was executed against the demo application and identified 7 total alerts across 4 risk levels. No High-risk alerts were identified. Two Medium-risk vulnerabilities were found, both related to missing security headers and misconfigured CORS policy. Three Low-risk issues were found involving server information disclosure, missing HSTS header, and timestamp leakage.

2.1 Alert Count by Risk Level

Risk Level	Count	% of Total
High	0	0.0%
Medium	2	28.6%
Low	3	42.9%
Informational	2	28.6%
Total	7	100%

2.2 Vulnerabilities Identified

Vulnerability	Risk	Count	CWE
Content Security Policy (CSP) Header Not Set	Medium	5	CWE-693
Cross-Domain Misconfiguration (CORS)		5	CWE-264
Server Leaks Version Information	Low	3	CWE-497
Strict-Transport-Security (HSTS) Not Set	Low	5	CWE-319
Timestamp Disclosure — Unix	Low	5	CWE-497
Modern Web Application (SPA)	Informational	5	N/A
Re-examine Cache-Control Directives	Informational	5	CWE-525

3. Validation Risk Register

All identified vulnerabilities have been converted into structured risk entries below. Each risk is assessed for probability, impact, and overall risk level, with a recommended mitigation action.

Risk ID	Risk Description	Source	Evidence	Prob.	Impact	Level	Mitigation Action
VR-01	CSP Header Not Set — allows XSS & data injection across 5 endpoints	ZAP Report Week 13	CWE-693, OWASP A05:2021	High	High	Critical	Add Content-Security-Policy header; define allowed content sources
VR-02	Cross-Domain Misconfiguration — permissive CORS allows unauthorized cross-origin requests	ZAP Report Week 13	CWE-264, WASC-14	High	High	Critical	Restrict CORS to trusted origins; remove wildcard Access-Control-Allow-Origin
VR-03	Server Leaks Version Info via HTTP Response Header — stack disclosed	ZAP Report Week 13	CWE-497, WASC-13	Medium	Medium	Moderate	Mask or suppress the Server response header value
VR-04	HSTS Header Not Set — protocol downgrade and MITM attacks possible	ZAP Report Week 13	CWE-319, WASC-15	Medium	High	High	Add Strict-Transport-Security header with min max-age=31536000
VR-05	Timestamp Disclosure (Unix) — internal timestamps exposed in HTTP responses	ZAP Report Week 13	CWE-497, WASC-13	Low	Low	Low	Strip Unix timestamps from HTTP responses
VR-06	Cache-Control Not Configured — sensitive content may be browser-cached	ZAP Report Week 13	CWE-525, WASC-13	Low	Medium	Low	Set Cache-Control: no-store for authenticated endpoints
VR-07	Modern SPA Framework Detected — client-side attack surface present	ZAP Report Week 13	Informational Alert	Low	Low	Informational	Review SPA routing; ensure no sensitive data exposed client-side

*** Risk Level Key:** Critical = High Prob. + High Impact | High = Medium Prob. + High Impact | Moderate = Medium/Medium | Low = Low/Low

4. Evidence Summary

The following evidence artifacts have been collected and organized to support the findings documented in this dossier. All evidence was generated during the Week 13 security validation phase.

#	Evidence Item	Location	Description
E-01	ZAP Scan Report (HTML)	SecurityReports/ZAP-Scan-Report.html	Full ZAP report generated on 20 May 2026; includes all alerts, requests, and responses
E-02	Vulnerability Summary	Week14_Evidence/Vulnerability_Summary.txt	Condensed list of all 7 vulnerabilities with CWE IDs and descriptions
E-03	Risk Register (CSV)	RiskRegisters/Risk_Register.csv	Structured risk register with probability, impact, and mitigation per vulnerability
E-04	Compliance Dossier (DOCX)	FinalReport/Final_Compliance_Dossier.docx	This document — complete audit-ready compliance package
E-05	Folder Structure	Compliance_Dossier/ (root)	Organized evidence tree: Requirements/, SecurityReports/, RiskRegisters/, Screenshots/, ValidationLogs/, FinalReport/

4.1 Compliance Folder Structure

Compliance_Dossier/

- |— SecurityReports/ (ZAP scan report HTML file)
- |— RiskRegisters/ (Risk_Register.csv — structured risk entries)
- |— Screenshots/ (Evidence screenshots from scanning sessions)
- |— ValidationLogs/ (ZAP log files and scan configuration)
- |— FinalReport/ (Final_Compliance_Dossier.docx)

5. Mitigation Actions

The following remediation actions are recommended to address the identified vulnerabilities. Actions are prioritized by risk level, with Critical and High issues requiring immediate attention.

Risk ID	Vulnerability	Priority	Owner	Mitigation Action
VR-01	CSP Header Not Set	Immediate	Dev Team	Add Content-Security-Policy HTTP response header defining all permitted content sources (scripts, styles, frames, images)
VR-02	Cross-Domain CORS Misconfiguration	Immediate	Dev Team	Replace wildcard (*) CORS policy with explicit allow-list of trusted domains; validate Origin header server-side
VR-04	HSTS Header Not Set	High	Dev/Ops Team	Add Strict-Transport-Security: max-age=31536000; includeSubDomains; preload header to all HTTPS responses
VR-03	Server Version Disclosure	Medium	Ops Team	Configure Heroku / web server to suppress or obscure the Server response header
VR-05	Timestamp Disclosure	Low	Dev Team	Review API and page responses to remove or obfuscate Unix timestamps from HTTP responses
VR-06	Cache-Control Misconfiguration	Low	Dev Team	Set Cache-Control: no-store, no-cache, must-revalidate on all authenticated and sensitive pages
VR-07	Modern SPA Detected	Advisory	Security Team	Conduct SPA-specific security review; ensure client-side routing does not expose sensitive data or bypass auth controls

6. Conclusion

The Week 13 security validation scan of the OWASP Juice Shop demo application successfully identified 7 security alerts spanning Medium, Low, and Informational risk levels. No High or Critical vulnerabilities were detected during this passive scan cycle.

The two Medium-risk findings — missing Content Security Policy header and overly permissive CORS configuration — represent the highest priority items for remediation. Left unaddressed, these could facilitate Cross-Site Scripting (XSS) attacks and unauthorized cross-origin data access.

The three Low-risk findings (HSTS missing, server version disclosure, and timestamp leakage) collectively increase the attack surface and should be addressed in the next sprint. The informational findings provide useful insight into the application architecture and caching behavior.

All evidence has been organized and preserved in the Compliance_Dossier/ folder structure, and the risk register has been formally documented for audit trail purposes. This dossier constitutes the complete compliance evidence package for the Week 14 submission.